

HOW TO PROTECT AI AGENTS, RAG SYSTEMS, AND MCP SERVERS

A practical security manual for agentic AI, retrieval-augmented generation, tools, memory, identities, and human oversight

Alberto (Al) Leiva

Version 1.0 - July 2026

Human safety comes first. This manual is intended for lawful, authorized, and defensive use. AI agents can act on real systems. Always test in approved environments and require human oversight for high-impact actions.

1. What this manual protects

- AI agents that plan, reason, call tools, and take actions.
- RAG pipelines that retrieve enterprise documents or database content.
- MCP hosts, clients, servers, tools, prompts, and resources.
- Agent memory, task state, credentials, logs, and approval workflows.
- Single-agent and multi-agent systems.

2. Core security principles

- The model proposes; trusted application logic authorizes.
- Treat user input, retrieved content, tool output, and memory as untrusted.
- Use unique workload identities and least privilege.
- Separate read, write, execute, and administrative capabilities.
- Require explicit confirmation for sensitive actions.
- Log actions without unnecessarily retaining sensitive content.
- Design for safe failure, rollback, shutdown, and recovery.

3. Reference architecture

- User or calling application authenticates through an approved identity provider.
- An orchestration layer validates inputs, enforces policy, and tracks the user session.
- The agent receives only the tools and data required for the current task.
- RAG retrieval enforces source permissions at query time.
- MCP clients connect only to approved servers using authenticated and encrypted transport.
- High-impact tool calls pass through deterministic authorization and approval gates.
- Monitoring records identity, decision, tool, parameters, result, and approval.

4. Threat modeling agentic AI

- Map users, agents, models, memory stores, RAG indexes, tools, MCP servers, and external services.
- Identify every trust boundary and every place instructions can enter.
- Document what each tool can read, modify, execute, delete, send, purchase, or approve.
- Estimate the blast radius of a compromised agent identity or poisoned memory.
- Identify people who could be harmed by incorrect, biased, deceptive, or unauthorized actions.

5. Identity and authorization

- Give each production agent or service a unique identity where supported.
- Prefer short-lived tokens, managed identities, workload identity federation, or OAuth-based access.
- Do not use one shared administrator credential across agents.

- Authorize every tool call in application logic and in the target service.
- Bind the initiating human user to the action so the agent cannot exceed that user's rights.
- Review dormant identities, permissions, and credentials regularly.

6. Tool security and action controls

- Use allowlists for tools, methods, destinations, file paths, and data classes.
- Validate structured arguments against strict schemas.
- Reject unexpected fields, ambiguous actions, command fragments, and unsafe paths.
- Apply rate limits, timeouts, output-size limits, and transaction limits.
- Use dry-run or preview modes before destructive changes.
- Require human approval for financial, legal, personnel, safety, security, deletion, and privilege-changing actions.
- Prevent the model from changing its own permissions or approval rules.

7. Securing RAG

- Enforce authorization at query time, not only when documents are indexed.
- Preserve source access controls and use security trimming.
- Track provenance, owner, classification, update date, and retention status.
- Scan uploads and reject unsupported or dangerous file types.
- Treat retrieved passages as data rather than trusted instructions.
- Limit retrieved context and require citations.
- Detect poisoned content, indirect prompt injection, stale permissions, and cross-tenant leakage.
- Remove deleted or revoked content from indexes promptly.

8. Protecting memory and state

- Separate short-term conversation state from durable memory.
- Store only information needed for an approved purpose.
- Do not place secrets, unrestricted credentials, or sensitive personal data in agent memory.
- Tag memory with source, owner, classification, confidence, and expiration.
- Require validation before memory can influence a high-impact action.
- Provide mechanisms to inspect, correct, and delete stored memory.

9. MCP security

- Maintain an approved inventory of MCP servers, owners, versions, and business purposes.
- Use authenticated and encrypted connections.
- Implement OAuth 2.1 or another approved authorization method for remote servers.
- Do not use session identifiers as authentication.
- Use secure, non-predictable session identifiers and verify every inbound request.

- Validate all tool inputs, enforce access control, rate-limit calls, and sanitize outputs.
- Show users sensitive tool inputs before execution and obtain confirmation.
- Validate tool results before they are passed back to the model.
- Pin dependencies and monitor third-party MCP servers for unexpected changes.

10. Prompt injection and tool poisoning

- Separate system instructions, user instructions, retrieved content, memory, and tool output.
- Never allow documents or tool descriptions to silently redefine policy.
- Treat tool metadata and server-provided descriptions as potentially malicious.
- Detect attempts to reveal secrets, invoke hidden tools, bypass approvals, or redirect data.
- Use independent policy checks that cannot be overridden by natural-language text.
- Test direct injection, indirect injection, tool-description poisoning, memory poisoning, and rug-pull scenarios.

11. Multi-agent systems

- Define which agent is allowed to delegate, approve, or terminate work.
- Prevent privilege accumulation when one agent calls another.
- Authenticate inter-agent messages and preserve the original user context.
- Limit recursion, task depth, token use, tool calls, and elapsed time.
- Detect conflicting instructions and circular workflows.
- Provide an emergency stop that halts the entire workflow.

12. Human oversight and accessibility

- Present proposed actions, affected resources, parameters, expected impact, and rollback options.
- Use plain language and accessible confirmation screens.
- Do not use dark patterns or misleading urgency.
- Allow users to challenge, correct, or appeal important outcomes.
- Provide alternative workflows for people who use assistive technology.
- Require trained human review where errors could materially affect rights, safety, employment, finances, or access to services.

13. Logging, monitoring, and detection

- Record initiating user, agent identity, model or configuration version, tool, parameters, result, approval, and timestamp.
- Monitor unusual tool sequences, repeated denials, high-volume retrieval, privilege changes, and new MCP servers.
- Alert on sensitive-data access, disabled safeguards, unexpected network destinations, and large output transfers.

- Protect logs against alteration and define retention based on risk and privacy requirements.
- Avoid storing complete prompts and outputs unless there is a justified need.

14. Testing and red teaming

- Test only with written authorization and defined scope.
- Test cross-user and cross-tenant data leakage.
- Test direct and indirect prompt injection.
- Test tool misuse, parameter manipulation, command injection, and unauthorized delegation.
- Test poisoned memory, poisoned documents, malicious tool descriptions, and compromised MCP servers.
- Test denial of service, uncontrolled loops, cost amplification, and excessive autonomy.
- Record expected behavior, actual behavior, severity, owner, remediation, and retest evidence.

15. Incident response

- Disable the affected agent, tool, MCP server, identity, or connector.
- Preserve logs, memory state, prompts, retrieved sources, tool results, and configuration versions.
- Revoke tokens and rotate secrets.
- Remove poisoned content and rebuild indexes or memory stores when required.
- Assess unauthorized actions, data exposure, and impact on people.
- Notify legal, privacy, compliance, customers, or regulators according to policy and law.
- Retest controls before restoring service.

16. Governance and evidence

- Maintain an inventory of agents, RAG systems, MCP servers, tools, owners, data, and risk tiers.
- Document approved purpose, prohibited uses, human oversight, and shutdown authority.
- Maintain architecture diagrams, data-flow diagrams, threat models, evaluations, and risk acceptances.
- Review suppliers, open-source components, model providers, and MCP servers.
- Map controls to NIST AI RMF, NIST CSF, OWASP guidance, and applicable organizational requirements.

17. 30/60/90-day implementation plan

- Days 1-30: inventory systems, identify owners, remove abandoned agents and servers, enable logs, and block public or excessive access.
- Days 31-60: implement unique identities, least privilege, RAG security trimming, MCP authorization, tool allowlists, and approval gates.
- Days 61-90: perform adversarial testing, integrate monitoring, exercise incident response, automate evidence, and establish periodic reviews.

18. Production readiness checklist

- ☐ Named business and technical owners
- ☐ Approved purpose and prohibited uses
- ☐ Agent, RAG, MCP, tools, and data inventory
- ☐ Threat model reviewed
- ☐ Unique identities and least privilege
- ☐ Query-time RAG authorization tested
- ☐ MCP authorization and secure sessions
- ☐ Tool schemas, allowlists, and limits
- ☐ Human approval for high-impact actions
- ☐ Prompt-injection and poisoning tests
- ☐ Logging, alerting, and privacy controls
- ☐ Emergency stop and rollback tested
- ☐ Incident response exercised
- ☐ Accessibility and appeal reviewed
- ☐ Final security approval recorded

19. Sample risk register

Risk	Impact	Controls	Owner
Poisoned RAG document changes agent behavior	Data disclosure or unauthorized tool use	Source validation, instruction separation, query-time authorization, testing	AI Platform Owner
Third-party MCP server changes tool behavior	Unexpected data transfer or destructive action	Approved inventory, version pinning, authorization, output validation, monitoring	Integration Owner
Agent uses excessive privileges	Large blast radius	Unique identity, least privilege, approval gates, periodic review	Security Engineering

20. Official references

- OWASP Agentic AI Threats and Mitigations: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- OWASP Securing Agentic Applications Guide: <https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0/>
- OWASP Top 10 for Agentic Applications 2026: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- Model Context Protocol Security Best Practices:
https://modelcontextprotocol.io/docs/tutorials/security/security_best_practices
- MCP Authorization: <https://modelcontextprotocol.io/docs/tutorials/security/authorization>
- MCP Tool Security Considerations:
<https://modelcontextprotocol.io/specification/2025-06-18/server/tools>
- NIST AI RMF: <https://www.nist.gov/itl/ai-risk-management-framework>
- NIST AI RMF Generative AI Profile: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- Microsoft Security Planning for LLM Applications:
<https://learn.microsoft.com/ai/playbook/technology-guidance/generative-ai/mlops-in-openai/security/security-plan-llm-application>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.